

1. Apa yang Dimaksud dengan Zeus Malware?

Zeus malware, yang juga dikenal dengan nama Zbot atau GameOver Zeus, adalah salah satu jenis *trojan horse* perbankan yang paling terkenal dan berbahaya dalam sejarah siber. Muncul pertama kali sekitar tahun 2007, Zeus dirancang khusus untuk mencuri informasi finansial dan kredensial sensitif dari komputer yang terinfeksi. Seiring waktu, malware ini terus berevolusi dan melahirkan berbagai varian yang lebih canggih, menjadikannya ancaman persisten bagi individu maupun institusi finansial di seluruh dunia.

Pada intinya, Zeus berfungsi sebagai *tool* pencurian data yang sangat efektif. Tujuan utamanya adalah mendapatkan akses ke data perbankan daring (online banking), informasi kartu kredit, kredensial *login* untuk berbagai layanan daring, dan data pribadi lainnya. Zeus melakukan ini dengan cara menyisipkan dirinya ke dalam sistem operasi dan memantau aktivitas pengguna, khususnya saat mereka berinteraksi dengan situs-situs finansial.

Meskipun aktivitas utamanya adalah pencurian data finansial, Zeus juga dikenal karena kemampuannya untuk berinteraksi dengan sistem komputer korban dalam berbagai cara, termasuk menginstal *malware* tambahan, memodifikasi konfigurasi sistem, atau bahkan mengubah situs web yang dikunjungi korban dalam upaya untuk menipu mereka agar memberikan informasi lebih lanjut. Ketenaran Zeus tidak hanya karena efektivitasnya, tetapi juga karena kode sumbernya sempat bocor ke publik, yang memungkinkan banyak penjahat siber lainnya untuk membuat varian-variannya sendiri, memperluas jangkauan dan bahayanya.

2. Bagaimana Cara Kerja Zeus Malware?

Cara kerja Zeus malware terbilang kompleks dan terkoordinasi, mencakup beberapa tahapan dari infeksi hingga pencurian data. Berikut adalah penjelasan detail mengenai mekanismenya:

a. Vektor Infeksi Awal: Zeus biasanya menyebar melalui metode rekayasa sosial (*social engineering*) yang menipu pengguna agar mengunduh dan menjalankan *malware* tersebut. Vektor serangan umum meliputi:

- **Email Phishing:** Penjahat siber mengirim email yang tampak sah, seringkali meniru bank, institusi pemerintah, atau perusahaan terkenal. Email ini berisi lampiran berbahaya (misalnya, dokumen Word atau PDF yang menyisipkan kode jahat) atau tautan ke situs web palsu yang mengunduh Zeus secara otomatis.
- **Drive-by Downloads:** Pengguna mengunjungi situs web yang telah terkompromi atau berbahaya, dan Zeus secara otomatis diunduh dan diinstal tanpa sepengetahuan atau izin pengguna. Ini seringkali memanfaatkan kerentanan pada *browser* web atau *plugin* yang sudah usang.
- **Payload dari Malware Lain:** Terkadang, Zeus diinstal sebagai *payload* sekunder oleh jenis *malware* lain yang sudah ada di sistem korban.

b. Instalasi dan Persistensi: Setelah berhasil masuk ke sistem, Zeus akan berusaha untuk menginstal dirinya sendiri dan memastikan ia tetap berjalan di latar belakang. Proses ini sering melibatkan:

- **Menyalin Diri:** Zeus menyalin *file* eksekusinya ke lokasi tersembunyi di dalam sistem, seringkali di direktori sistem atau *folder* pengguna.
- **Modifikasi Registry:** Malware ini akan memodifikasi entri *registry* Windows atau pengaturan sistem lainnya untuk memastikan ia otomatis berjalan setiap kali sistem dinyalakan ulang. Ini seringkali dilakukan dengan menambahkan entri ke *startup folder* atau *registry run keys*.
- **Menyamarkan:** Zeus sering menyamarkan dirinya sebagai *file* sistem yang sah atau proses yang umum agar tidak terdeteksi oleh pengguna atau perangkat lunak keamanan yang kurang canggih.

c. Komunikasi dengan Server Perintah dan Kontrol (C2): Setelah berhasil diinstal, Zeus akan menjalin komunikasi dengan server Perintah dan Kontrol (*Command and Control* - C2) yang dioperasikan oleh penjahat siber. Komunikasi ini berfungsi untuk:

- **Menerima Perintah:** Zeus menerima instruksi baru dari penyerang, seperti situs web mana yang harus dipantau, data apa yang harus dicuri, atau *plugin* tambahan apa yang harus diunduh.
- **Mengirim Data Curian:** Data finansial atau informasi pribadi yang berhasil dicuri akan dikirimkan kembali ke server C2 ini.
- **Memperbarui Diri:** Varian Zeus yang lebih canggih dapat menerima pembaruan dari server C2 untuk meningkatkan kemampuannya atau untuk menghindari deteksi.

d. Pencurian Data Finansial (Man-in-the-Browser Attack): Mekanisme utama pencurian data oleh Zeus adalah melalui serangan *Man-in-the-Browser* (MitB) atau *webinjects*. Ini adalah fitur yang membuatnya sangat berbahaya:

- **Injeksi Kode:** Saat pengguna mengunjungi situs web perbankan atau finansial yang telah ditargetkan oleh Zeus (daftar target ini diunduh dari server C2), *malware* ini akan menyisipkan kode berbahaya (*webinjects*) langsung ke dalam halaman web yang dilihat oleh *browser* korban. Kode ini dieksekusi di sisi *client*, bukan *server*.
- **Manipulasi Tampilan:** *Webinjects* dapat mengubah tampilan situs web secara *real-time*. Misalnya, mereka dapat menambahkan *field input* palsu untuk nomor PIN, tanggal lahir, atau pertanyaan keamanan tambahan yang biasanya tidak diminta oleh bank. Pengguna, yang melihat situs bank yang tampak sah, akan memasukkan informasi ini, yang kemudian langsung ditangkap oleh Zeus.
- **Keylogging:** Zeus juga dapat menggunakan fungsi *keylogging* untuk merekam setiap ketukan tombol yang dilakukan pengguna, khususnya saat memasukkan

Nama: Ariski Myardi
NIM: 1103220019

username dan *password* di situs-situs finansial.

- **Form Grabbing:** *Malware* ini mampu mencegat data yang dikirimkan melalui *form* web, bahkan sebelum data tersebut dienkripsi dan dikirim ke *server* yang sah.
- **Session Hijacking:** Dalam beberapa kasus, Zeus dapat mencuri *session cookie* pengguna, memungkinkan penyerang untuk mengambil alih sesi *login* yang aktif tanpa perlu kredensial *username* dan *password*.

e. **Modifikasi Transaksi:** Varian Zeus yang lebih canggih bahkan dapat memanipulasi transaksi yang sedang berjalan. Misalnya, jika pengguna mencoba melakukan transfer dana, Zeus dapat mengubah nomor rekening tujuan atau jumlah transfer tanpa sepengetahuan pengguna. Konfirmasi transaksi yang ditampilkan kepada pengguna mungkin tetap menampilkan detail yang benar, tetapi *malware* telah mengubahnya di belakang layar.

f. **Pencegahan Deteksi:** Zeus sangat licin dan menggunakan berbagai teknik untuk menghindari deteksi oleh perangkat lunak antivirus:

- **Polymorphism:** *Malware* ini dapat mengubah kode *file* eksekusinya setiap kali menyebar, membuat *signature*-nya berbeda dan sulit dideteksi oleh antivirus berbasis *signature*.
- **Rootkit Capabilities:** Beberapa varian Zeus memiliki kemampuan *rootkit* untuk menyembunyikan *file* dan prosesnya dari sistem operasi dan perangkat lunak keamanan.
- **Mendeteksi Lingkungan Virtual:** Beberapa varian Zeus dirancang untuk mendeteksi jika mereka berjalan di lingkungan virtual (seperti *sandbox* yang digunakan peneliti keamanan) dan akan menahan diri untuk tidak beroperasi, sehingga mempersulit analisis.

3. Perangkat yang Terdampak oleh Zeus Malware dan Vektor Serangan

Zeus malware dirancang untuk menargetkan sistem operasi yang umum digunakan, khususnya untuk platform desktop. Memahami perangkat yang terdampak dan vektor serangannya sangat penting untuk upaya pencegahan.

a. Perangkat yang Terdampak:

- **Sistem Operasi Windows:** Ini adalah target utama dan hampir eksklusif dari Zeus malware. Mayoritas varian Zeus dirancang untuk menginfeksi dan beroperasi pada berbagai versi Microsoft Windows, mulai dari Windows XP hingga versi yang lebih baru, termasuk Windows 7, 8, dan 10. Struktur sistem *registry*, *file system*, dan API Windows yang umum digunakan oleh Zeus untuk persistensi dan operasi jahatnya.
- **Meskipun Fokus pada Windows:** Penting untuk dicatat bahwa *malware* perbankan modern yang terinspirasi oleh Zeus (atau varian turunannya) telah mulai menargetkan platform lain, seperti Android untuk *mobile banking* melalui

Nama: Ariski Myardi
NIM: 1103220019

malware yang menyamar sebagai aplikasi perbankan sah. Namun, Zeus *original* dan varian utamanya secara spesifik menasar lingkungan Windows.

b. Vektor Serangan yang Ada:

Vektor serangan adalah jalur atau metode yang digunakan penyerang untuk mengirimkan *malware* ke sistem target. Untuk Zeus malware, vektor serangan utamanya memanfaatkan kelemahan manusia (*social engineering*) dan kerentanan perangkat lunak.

1. Email Phishing:

- **Deskripsi:** Ini adalah vektor serangan paling umum. Penyerang mengirimkan email yang menyamar sebagai komunikasi yang sah dan terpercaya. Email ini dirancang untuk memanipulasi korban agar melakukan tindakan tertentu.
- **Mekanisme:**
 - **Lampiran Berbahaya:** Email berisi lampiran seperti dokumen Word (.doc, .docx), PDF (.pdf), *spreadsheet* Excel (.xls, .xlsx), atau *file* ZIP yang tampaknya tidak berbahaya. Namun, *file-file* ini mengandung *script* atau makro jahat yang, saat dibuka atau diaktifkan oleh pengguna (seringkali dengan peringatan "Enable Content" atau "Aktifkan Konten"), akan mengunduh dan menginstal Zeus di latar belakang.
 - **Tautan Berbahaya (Malicious Links):** Email mengarahkan pengguna ke situs web palsu yang menyerupai situs bank, toko *online*, atau layanan populer lainnya. Situs ini kemudian akan mencoba mengunduh *malware* secara otomatis (melalui *drive-by download*) atau meminta pengguna untuk mengunduh *file* yang "diperlukan".
- **Contoh Konteks:** Email yang mengklaim dari bank Anda meminta untuk "memverifikasi akun" karena "aktivitas mencurigakan," atau pemberitahuan pengiriman paket palsu yang meminta Anda untuk "membuka lampiran untuk detail pengiriman."

2. Drive-by Downloads:

- **Deskripsi:** Ini terjadi ketika *malware* diunduh dan diinstal ke komputer pengguna secara otomatis tanpa interaksi langsung dari pengguna (seperti mengklik tombol unduh).
- **Mekanisme:**
 - **Situs Web Terkompromi:** Penyerang menyuntikkan kode berbahaya ke situs web yang sah namun rentan. Ketika pengguna mengunjungi situs ini, *malware* akan diunduh secara diam-diam.
 - **Exploit Kits:** Situs web berbahaya sering menggunakan *exploit kits* yang secara otomatis memindai kerentanan pada *browser* web

Nama: Ariski Myardi
NIM: 1103220019

pengguna atau *plugin* (*Java, Flash, Adobe Reader* yang sudah usang). Jika kerentanan ditemukan, *exploit kit* akan mengirimkan Zeus sebagai *payload* untuk menginfeksi sistem.

- **Contoh Konteks:** Mengunjungi situs berita atau blog populer yang telah diretas, dan komputer Anda terinfeksi tanpa Anda menyadarinya.

3. Botnet Lain atau Malware Sekunder:

- **Deskripsi:** Zeus dapat diinstal sebagai *payload* sekunder oleh *malware* lain yang telah berhasil menginfeksi sistem. Ini berarti komputer Anda mungkin sudah menjadi bagian dari *botnet* lain atau terinfeksi *malware* pembuka pintu.
- **Mekanisme:** Jika sebuah komputer sudah terinfeksi oleh *malware* jenis *downloader* atau *backdoor*, *malware* tersebut dapat menerima instruksi dari *server* C2-nya untuk mengunduh dan menjalankan Zeus. Dalam skenario ini, Zeus menjadi salah satu dari berbagai alat yang digunakan oleh operator *botnet*.
- **Contoh Konteks:** Komputer Anda terinfeksi oleh *malware* generik yang kemudian "menjual" akses atau menginstal *malware* lain, termasuk Zeus, sebagai bagian dari kampanye yang lebih besar.

4. Malvertising:

- **Deskripsi:** Penggunaan iklan *online* yang sah untuk menyebarkan *malware*.
- **Mekanisme:** Penyerang menyisipkan kode berbahaya ke dalam iklan digital yang ditampilkan di situs web yang sah. Ketika iklan tersebut dimuat di *browser* pengguna, kode jahat akan dieksekusi dan dapat mengarahkan pengguna ke situs web berbahaya atau langsung memicu *drive-by download* Zeus.
- **Contoh Konteks:** Menjelajahi situs web berita populer, dan iklan yang ditampilkan di situs tersebut ternyata adalah sumber infeksi Zeus.

Pencegahan dan Mitigasi: Untuk melindungi diri dari Zeus dan *malware* sejenis, langkah- langkah pencegahan sangat krusial:

- Selalu berhati-hati terhadap email dan tautan yang mencurigakan (tidak mengklik tautan atau membuka lampiran dari sumber yang tidak dikenal atau tidak terverifikasi).
- Memastikan sistem operasi dan semua perangkat lunak (*browser*, *plugin*, antivirus) selalu diperbarui ke versi terbaru untuk menambal kerentanan yang diketahui.
- Menggunakan perangkat lunak antivirus/anti-malware yang andal dan selalu memperbarui *database* definisinya.
- Mengaktifkan *firewall*.
- Melakukan *backup* data penting secara teratur.

Nama: Ariski Myardi
NIM: 1103220019

- Meningkatkan kesadaran akan teknik rekayasa sosial dan tanda-tanda situs web atau email palsu.

Zeus malware adalah pengingat betapa berbahayanya ancaman siber dan pentingnya praktik keamanan yang kuat dalam penggunaan internet.